PENETRATION TEST REPORT

Web Application Security Assessment

Prepared by: GILLIAN NGESO

Client: CYBERSECURITY GROUP C

Date: 06/11/2026

Classification: CONFIDENTIAL

1. ENGAGEMENT OVERVIEW

Client	CYBERSECURITY GROUP C
Target	https://vulnerabilityreportgenerator.lovable.app
Assessment Type	Web Application Penetration Test
Test Period	03/11/2026 – 06/11/2026
Tester	GILLIAN NGESO
Methodology	Grey Box
Classification	CONFIDENTIAL

2. EXECUTIVE SUMMARY

The web application security assessment was conducted against **https://vulnerabilityreportgenerator.lovable.app** using a Grey Box testing methodology. Testing activities included network reconnaissance, service enumeration, TLS/SSL configuration review, HTTP information gathering, safe vulnerability scanning, and web application testing using Nmap and Burp Suite. The assessment aimed to identify security weaknesses that could affect the confidentiality, integrity, and availability of the application.

No Critical, High, Medium, or Low severity vulnerabilities were identified during the assessment. The application demonstrated a generally strong security posture, including modern TLS support, Cloudflare-protected web services, and the absence of publicly known vulnerabilities during testing. While no exploitable weaknesses were discovered within the assessment scope, ongoing vulnerability management, secure configuration practices, and periodic penetration testing are recommended to maintain security resilience.

Critical	High	Medium	Low	Info
0	0	0	0	6

3. SCOPE

The following targets were included in the scope of this assessment:

- https://vulnerabilityreportgenerator.lovable.app — Main application
- https://api.login.com — REST API
- https://api.analytics.com— Dashboard

The following were explicitly out of scope:

- Third-party services and integrations
- Physical security testing
- Digital attack method
- Denial of Service (DoS) attacks

4. METHODOLOGY

This assessment followed the OWASP Web Security Testing Guide (WSTG) methodology and covered the following phases:

- Reconnaissance — Passive and active information gathering
- Enumeration — Directory brute-forcing, subdomain discovery, technology fingerprinting
- Vulnerability Assessment — Automated scanning and manual testing
- Exploitation — Controlled exploitation of identified vulnerabilities
- Post-Exploitation — Privilege escalation, lateral movement (if applicable)
- Reporting — Documentation of all findings with remediation guidance

5. FINDINGS

FINDING 01 Externally Accessible Network Services

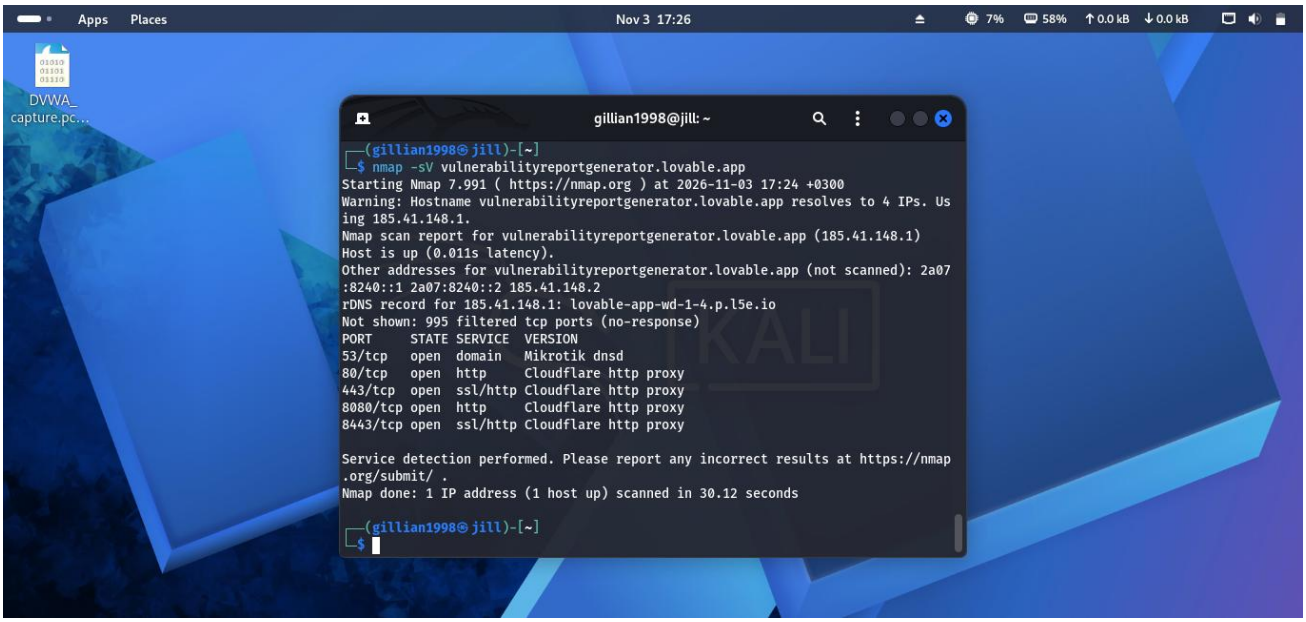
Informational

URL	https://vulnerabilityreportgenerator.lovable.app
Parameter	N/A
CVSS Score	N/A (Informational)
CWE	CWE-200: Exposure of Information

Description

External reconnaissance identified several publicly accessible network services including DNS, HTTP, HTTPS, and alternate web service ports. Service enumeration determined that web-facing services are protected behind Cloudflare proxy infrastructure, reducing direct exposure of the origin server. No unauthorized services or security weaknesses were identified during testing.

Proof of Concept



Impact

No direct vulnerability was identified. However, all internet-facing services contribute to an application's attack surface and should be continuously monitored to prevent exposure resulting from future misconfigurations or software vulnerabilities.

Remediation

- Periodically review externally accessible services and ports.
- Disable services that are no longer required.
- Maintain Cloudflare protection and monitoring controls.
- Conduct regular attack-surface reviews.

FINDING 02 Secure TLS Configuration Assessment

Informational

URL	https://vulnerabilityreportgenerator.lovable.app
Parameter	N/A
CVSS Score	N/A(Informational)
CWE	CWE-326: Inadequate Encryption Strength

Description

SSL/TLS testing confirmed that the application supports TLS 1.2 and TLS 1.3. No deprecated protocols or weak cipher suites were identified during the assessment. The cryptographic configuration aligns with current security best practices and provides strong protection for data transmitted between clients and the application.

Proof of Concept

```
nmap --script ssl-enum-ciphers -p 443 vulnerabilityreportgenerator.lovable.app
```

Impact

No immediate security risk was identified. The current transport-layer security configuration effectively protects communications against interception and downgrade attacks.

Remediation

- Periodically review externally accessible services and ports.
- Disable services that are no longer required.
- Maintain Cloudflare protection and monitoring controls.
- Conduct regular attack-surface reviews.

FINDING 03 Vulnerability Assessment Results

Informational

URL	https://vulnerabilityreportgenerator.lovable.app
Parameter	N/A
CVSS Score	N/A(Informational)
CWE	Not Applicable

Description

Automated vulnerability assessment activities were conducted using Nmap vulnerability detection scripts to identify known weaknesses within exposed services. The assessment did not detect any publicly known vulnerabilities or exploitable security issues within the testing scope.

Proof of Concept

```
nmap --script vuln vulnerabilityreportgenerator.lovable.app
```

Impact

No exploitable vulnerabilities were identified during testing. The results indicate an overall positive external security posture at the time of assessment.

Remediation

- Perform regular vulnerability assessments.
- Maintain an effective patch-management process.
- Continuously monitor infrastructure and dependencies for newly disclosed vulnerabilities.
- Integrate security testing into the SDLC.

FINDING 04 Authentication Controls Enforced

Informational

URL	https://api.analytics.com
Parameter	N/A
CVSS Score	N/A(Informational)
CWE	CWE-306 – Missing Authentication for Critical Function (Not Observed)

Description

Authentication testing was performed using Burp Suite to evaluate the effectiveness of access control mechanisms protecting application resources. During testing, requests were intercepted and manipulated to assess whether protected functionality could be accessed without proper authentication.

Attempts to access authenticated functionality after removing authentication tokens or session cookies resulted in application-generated error responses. The application did not allow unauthorized access to protected resources, indicating that authentication validation is enforced on server-side requests.

Proof of Concept

- Authentication tokens were removed from intercepted requests.
- Requests were resent using Burp Repeater.
- The application returned **400 Bad Request** responses for unauthorized requests.
- Access to protected functionality was not granted.

Impact

No security vulnerability was identified. The observed behavior indicates that authentication controls are functioning as intended and provide protection against unauthorized access attempts.

Remediation

- Continue enforcing server-side authentication validation.
- Implement regular reviews of access control mechanisms.
- Monitor authentication logs for abnormal access attempts.
- Periodically test authentication workflows to ensure security controls remain effective.

FINDING 05 Invalid Token Handling

Informational

URL	https://api.analytics.com
Parameter	N/A
CVSS Score	N/A(Informational)
CWE	CWE-287 – Improper Authentication (Not Observed)

Description

Token validation testing was conducted by replacing valid authentication tokens with invalid or modified values and replaying the requests through Burp Repeater. The objective was to determine whether the application properly validates authentication tokens before processing requests.

The application consistently rejected requests containing invalid authentication tokens and returned error responses rather than granting access to protected functionality. This indicates that token integrity verification and authentication checks are being performed.

Proof of Concept

- Authentication tokens were modified manually within Burp Suite.
- Requests containing altered tokens were replayed.
- The application responded with **400 Bad Request** errors.
- No unauthorized access was achieved

Impact

No exploitable weakness was identified. Proper validation of authentication tokens reduces the risk of session hijacking, token tampering, and unauthorized account access.

Remediation

- Continue validating authentication tokens server-side.
- Implement token expiration and rotation mechanisms where applicable.
- Review authentication logs for repeated token manipulation attempts.
- Periodically conduct authentication and session management assessments.

FINDING 06 Limited Visibility of Login Request Parameters

Informational

URL	https://api.login.com
Parameter	N/A
CVSS Score	N/A(Informational)
CWE	CWE-200 – Exposure of Information (Not Observed)

Description

Login form testing was conducted using Burp Suite proxy interception and the Repeater module to evaluate input handling and authentication behavior. While Burp Suite successfully intercepted authentication requests, user credential data and underlying JSON payloads were not visible within the captured requests. As a result, deeper testing of input validation controls and sql injection-based attack vectors could not be performed within the available testing context.

The absence of visible credential payloads may be attributable to client-side processing, third-party authentication mechanisms, API abstractions, or application architecture decisions.

Proof of Concept

- Login requests were intercepted successfully.
- Email and password values were modified during testing.
- Authentication payload data was not exposed within intercepted requests.
- Manual injection testing could not be completed.
- Requests forwarded to Burp Repeater returned **202 OK** responses without exposing authentication parameters

Impact

No security vulnerability was identified. The observed behavior indicates that authentication controls are functioning as intended and provide protection against unauthorized access attempts.

Remediation

- Include authenticated test accounts during future assessments to enable deeper validation of authentication workflows.
- Expand testing scope to include API-level security assessments.
- Conduct application security reviews focused on authentication and input validation logic.

6. REMEDIATION SUMMARY

#	Finding	Severity	Status	Priority
01	Externally Accessible Network Services	Informational	Open	Low
02	Secure TLS Configuration Assessment	Informational	Open	Low
03	Vulnerability Assessment Results	Informational	Open	Low
04	Authentication Controls Enforced	Informational	Open	Low
05	Invalid Token Handling	Informational	Open	Low
06	Limited Visibility of Login Request Parameters	Informational	Open	Low

7. CONCLUSION

The security assessment of **VulnReport AI** found no Critical, High, Medium, or Low severity vulnerabilities within the defined scope of testing. Network reconnaissance, vulnerability scanning, SSL/TLS assessment, and manual testing using Burp Suite confirmed that the application's security controls are functioning as intended.

Authentication mechanisms effectively prevented unauthorized access, invalid authentication tokens were properly rejected, and no exploitable weaknesses were identified in the tested functionality. The application also demonstrated strong security practices through the use of Cloudflare protection and modern TLS encryption standards.

Overall, the application exhibits a strong security posture. Although no vulnerabilities were discovered during the assessment, ongoing vulnerability management, regular security testing, timely patching, and continuous security monitoring are recommended to maintain resilience against emerging threats.

8. DISCLAIMER

This report was prepared solely for the use of the named client. The information contained herein is confidential and must not be disclosed to third parties without prior written consent. All testing was conducted within the agreed scope and with explicit authorization. The tester assumes no liability for any damages resulting from the use or misuse of this report.